

Risk ID	Asset	Threat	Vulnerability	Existing controls	L	I	Score	Level	Treatment	Annex A controls	Owner	Target Date	Residual	Source (evidence)
RSK-001	AST-004	Phishing → account compromise (proven 10/2025)	MFA disabled for standard users; no awareness training	Default M365 filtering		4	4	16	High	Modify	5.17, 8.5, 6.3, 8.7	M. Urban	31.3.2026	8 E03/2, E12
RSK-002	AST-001,007,011	Ransomware encrypting ERP, file server and connected NAS backups	No patching schedule; restore never tested; flat network; online-only backup	Endpoint AV; daily backups (untested)	3	5	15	High	Modify	8.8, 8.13, 8.22, 5.29	M. Urban/MSP	30.4.2026	8 E03/3-5, E07/2	
RSK-003	AST-005	Web attack on B2B e-shop (SQLi, credential stuffing)	No security requirements in dev contract; no security testing ever	HTTPS; provider firewall	3	4	12	High	Modify	8.29, 8.26, 5.20, 8.30	K. Bietliková	31.5.2026	6 E06/2, E10	
RSK-004	AST-003	Insider exfiltration of recipes to competitor	Whole production sees all recipes; no access reviews ever	NDA at hiring	2	5	10	Medium	Modify	5.18, 8.3, 5.11, 6.5	R. Čech	30.6.2026	5 E02/2, E03/3	
RSK-005	AST-009	Theft/loss of laptop with customer data	BitLocker on ~50 % only; no MDM	Password login	3	3	9	Medium	Modify	8.1, 8.24, 7.9	M. Urban	30.4.2026	4 E03/6, E08	
RSK-006	AST-010,008	Extended HQ–warehouse VPN outage (6 h precedent 2025)	Single link; no documented fallback	MSP SLA 8 h	3	3	9	Medium	Modify/Share	5.29, 5.30, 5.22	L. Hruška	30.6.2026	4 E05/2, E02/4	
RSK-007	AST-006	Breach of HR/payroll data (GDPR)	Whole finance dept has access; PayWell without MFA; no records of processing	Locked cabinet (paper)	2	4	8	Medium	Modify	5.18, 5.34, 8.5	J. Šimková	31.5.2026	4 E04/1-2	
RSK-008	AST-007,011	Power failure / UPS failure in server room	UPS unserviced since 2021; no test records	UPS present; AC works	2	4	8	Medium	Modify	7.11, 7.13	M. Urban	31.5.2026	4 E13	
RSK-009	AST-001,012	Compromise of MSP privileged remote access	4 MSP technicians share one RMM credential; no incident-notification duty	Contractual NDA	2	5	10	Medium	Modify	5.20, 5.21, 8.2, 8.5	ISMS Mgr	31.5.2026	5 E07/1,4, E09	
RSK-010	AST-015,007	Unauthorised physical access to server room	Door unlocked; key on kitchen board; no visitor log	Building entrance control	3	4	12	High	Modify	7.1, 7.2, 7.4	P. Kováč	31.3.2026	4 E13	
RSK-011	AST-001..016	Loss of IT knowledge (single admin leaves/ill)	No infrastructure documentation ("in my head"); no deputy	None	2	4	8	Medium	Modify	5.37, 8.9	M.Urban	30.6.2026	4 E03/1	
RSK-012	AST-013	BEC / fraudulent invoice payment (attempted 10/2025)	Supplier bank-change verification informal; no callback rule	2-step approval > €5k	3	4	12	High	Modify	5.14, 6.3, 8.7	J. Šimková	31.3.2026	6 E12, E04/6	
RSK-013	AST-002	Data leakage via private Dropbox (shadow IT, sales)	VPN avoidance; contracts/pricing in private cloud	None	4	3	12	High	Modify	5.10, 5.14, 8.12	K. Bietliková	31.5.2026	6 E06/1,3	
RSK-014	AST-014	Malware via unsupported Windows 7 terminals	EOL OS; shared use; USB sticks common	AV where possible	3	3	9	Medium	Modify	8.8, 8.19, 7.10, 8.22	R. Čech/MSP	30.9.2026	6 E08/7, E03/6,8, E07/3	
RSK-015	AST-005	E-shop outage at VPS provider	No backup/continuity clause; unclear e-shop backups	Provider redundancy (unverified)	2	3	6	Medium	Share/Modify	5.22, 5.30	K. Bietliková	30.6.2026	4 E10, E06/2	
RSK-016	AST-001,004	Inability to investigate an incident (no logs/monitoring)	Logs unmonitored; retention unknown; proven in 10/2025 (no analysis possible)	Default logging	4	3	12	High	Modify	8.15, 8.16, 5.28	M.Urban	30.6.2026	6 E03/7, E12	
RSK-017	AST-004,001	Ex-employee access after departure	Deprovisioning 2–3 days via informal e-mail; no asset checklist	Eventually disabled	3	3	9	Medium	Modify	5.18, 5.11, 6.5	J. Šimková	31.3.2026	4 E04/4	
RSK-018	AST-008	Unattributable warehouse actions / account misuse	3 shared WMS accounts; passwords written on monitor	Physical site security	4	2	8	Medium	Modify	5.16, 5.17	L.Hruška	15.5.2026	4 E05/1	
RSK-019	AST-016	Loss of domain/DNS control (private registrar account)	slovpack.sk on admin's personal account; no corporate control	Paid by company card	2	4	8	Medium	Modify	5.9, 8.9	M. Urban	31.3.2026	2 E03/9	
RSK-020	AST-006,002	GDPR non-compliance (no records of processing; unreported 2025 incident)	Records of processing missing; breach-assessment process absent	2018 legal directive (obsolete)	3	4	12	High	Modify	5.31, 5.34, 5.24	J. Šimková	30.6.2026	6 E04/2,5, E12	